

Certified Screening of Outbound Health Data Packages: Distribution-Free Guarantees on Over-Disclosure with Verifiable Audit Receipts

Younes Boujouard, Mayur Rele

Abstract—Outbound health-data packages frequently contain more than the recipient’s request requires, and no step in a typical exchange pipeline checks this before transmission. We study a screener that compares the content of an outbound FHIR package with the external request, flags possible excess for human review, and records a tamper-evident receipt of each check. Rather than reporting a score, we certify the screener’s operating point: using conformal risk control and Learn-then-Test, the flag threshold is chosen so that, with confidence $1 - \delta$, the expected missed-excess fraction, the expected fraction of wrongly flagged required elements and the probability of releasing a high-risk element unflagged are simultaneously bounded, for any package distribution, given a calibration set. We give a transfer bound under covariate shift between organizations and a verifiable certificate that lets an auditor recompute the guarantee from committed loss tables without patient data. The legal scope is restricted to flows where a necessity limit binds: 42 CFR Part 2 records and prior-authorization packages beyond the payer’s published documentation requirement, anchored on the CMS power-mobility-device checklist. On a released benchmark of 1,360 synthetic FHIR packages with policy-derived labels, six over-disclosure mechanisms and four generated organizations, a request allow-list was certified in all 20 splits with test risks of 0.004, 0.000 and 0.000 against targets of 0.05, 0.02 and 0.01, reached recall 1.00 on structured elements with zero wrongful flags, and cut residual excess by 70 to 95 percent in a workflow simulation, at 90 flags per package. An identifier redactor and DS4P sensitivity labels were refused certification. The transfer bound abstained at the available calibration size, and a permissioned chain detected no tampering case that a signed Merkle log with a captured snapshot did not. Results for local language-model screeners are pending in this draft. All guarantees are conditional on the policy-derived labels and are demonstrated on synthetic data only.

Index Terms—Conformal risk control, data minimization, health information exchange, HIPAA minimum necessary, 42 CFR Part 2, prior authorization, FHIR, audit logging, transparency logs, large language models.

I. INTRODUCTION

When one healthcare organization sends patient data to another, the package that leaves is often assembled by an export routine rather than by a person, and it frequently contains more than the recipient’s request requires: whole-chart exports, entire encounter bundles, copy-forward note text, and records governed by stricter rules than the request itself. Nothing in a typical exchange pipeline checks this before transmission.

Author affiliations, corresponding author, ORCIDs, funding and conflict-of-interest declarations (including the second author’s roles at Parachute Health, Nightfall AI and EC-Council) must be completed before submission. No employer data, code or evaluation was used in this study.

Existing safeguards act elsewhere: identifier redactors find protected health information but do not judge whether a given element was needed for a given purpose; access-control and consent ledgers decide who may receive a resource category but never inspect the content of an individual disclosure; and behavioral anomaly detectors watch who accessed what and when, not what was sent.

This paper studies a screener that inspects the content of an outbound package against the external request, flags elements that go beyond it for a human reviewer, and records a tamper-evident receipt of each check. Two design choices distinguish it from prior work. First, the screener never edits or releases anything: its output is a set of flags for human review, so the relevant outcomes are missed excess, wrongful flags on required content, and reviewer burden, rather than redaction accuracy alone. Second, and centrally, the screener’s operating point is not chosen to maximize a score on a test set; it is *certified*. Using conformal risk control and the Learn-then-Test framework, we select the flag threshold so that, with a stated confidence, the expected fraction of missed excess, the expected fraction of wrongly flagged required elements, and the probability of missing a high-risk element are all bounded at pre-specified levels for any package distribution, given a calibration set of labelled packages. The guarantee is distribution-free, so it can be demonstrated on synthetic data and inherited by any deployment that calibrates on its own packages; and because the certified threshold, the calibration commitment and the bound are written into the audit receipt, an auditor can recompute the guarantee without access to patient data.

The legal scope is chosen so that a necessity limit actually binds. Provider-to-provider treatment referrals are excluded, because the HIPAA minimum-necessary standard exempts them [1]; the study targets (i) substance-use disorder records under 42 CFR Part 2, where every use or disclosure must be limited to what is necessary for its purpose [2], and (ii) prior-authorization packages sent to payers that contain elements beyond the payer’s published documentation requirement, anchored on the CMS documentation checklist for power mobility devices [3], the HL7 Da Vinci documentation templates [4], and the CMS-0057-F prior-authorization API timeline [5]. Because a sender may reasonably rely on a covered-entity payer’s request [6], only content beyond the request is treated as checkable.

The contributions are:

- 1) a formulation of outbound disclosure screening as joint

risk control over two conflicting losses (missed excess and wrongful flags on required content) plus a package-level high-risk loss, with a finite-sample, distribution-free certification procedure (Theorem 1);

- 2) a transfer result showing how the guarantee carries from a calibration organization to a new one under covariate shift, with an explicit penalty in the shift magnitude and calibration size (Theorem 2);
- 3) a verifiable screening certificate bound into an audit receipt, so that the statistical guarantee itself, not only provenance, can be recomputed by an auditor from committed loss tables without patient data (Proposition 1);
- 4) a released benchmark of synthetic FHIR R4 disclosure packages with policy-derived, open-world element labels, six named over-disclosure mechanisms, generated organizations with different export habits, and an end-to-end workflow simulation with a simulated reviewer, drift and attack conditions, and an audit-store comparison under tampering.

The study is simulation-based. It establishes that the certification holds and what it costs; it does not establish performance on real organizational traffic, which requires a calibration set from that organization and is left to future work.

II. RELATED WORK

A. Compliance and Privacy Mechanisms for Health Data Exchange

Blockchain and smart-contract systems for healthcare compliance verify access decisions against consent and policy metadata. A representative design records patient-provider agreements as smart contracts and introduces a proof-of-compliance consensus over audit trails; its auditor nodes explicitly do not access protected health information and it contains no content inspection [7]. Anomaly detection for cross-provider exchange operates on audit logs (provider mismatch, off-hours access, access frequency) with rule-based and isolation-forest detectors, again without inspecting what was disclosed [8]. Identifier redaction and de-identification tools such as Presidio [9] detect names, dates and other identifiers; they answer whether a span contains an identifier, not whether an element was necessary for a request. The HL7 Data Segmentation for Privacy guide [10] assigns sensitivity and purpose-of-use labels that a policy engine can act on; it is a deterministic baseline in our experiments rather than a necessity judgment. The present work differs from all of these in inspecting the content of an individual outbound package against its request.

B. Language Models and Contextual Integrity

Language-model methods grounded in contextual integrity judge whether an information flow is appropriate for its context. GoldCoin grounds such judgments in privacy statutes including HIPAA using a dataset built from court cases [11]. DelegateCI-Bench scores task-conditioned disclosure at the span level, including over-disclosure and over-removal, with a medical challenge set, and trains a query rewriter [12]; its

inputs are free-text user queries sent to a cloud model, not structured organization-to-organization records. We position our screener as an application of these ideas to structured FHIR packages checked against an external request, and, unlike either, we certify its operating point rather than report a score.

C. Risk Control and Certification

Conformal risk control extends conformal prediction to control the expected value of any bounded monotone loss [13]; Learn-then-Test provides high-probability control of one or several risks over a finite grid of parameters using valid p-values and family-wise error control [14]. Weighted variants handle covariate shift through importance weighting [15], and finite-sample guarantees exist for non-monotone losses selected on a grid, with extensions to distribution shift [16]. Most closely related, Kotte studies when conformal risk control can certify structured language-model outputs such as entity recognition, JSON extraction and classification, with several concentration bounds and cross-dataset shift [17]; that work does not address disclosure screening, simultaneous privacy and utility risks, element-versus-package loss structure, or transfer between organizations, which are the objects of Theorems 1 and 2. We make no claim of new concentration results: the contribution is the disclosure-screening formulation, the joint certification, the organization-transfer bound for this loss structure, and the verifiable certificate.

D. Tamper-Evident Records

Append-only Merkle logs with inclusion and consistency proofs are standardized in Certificate Transparency [18]. Prior AI-and-blockchain audit designs record model identifiers, inputs and outputs on permissioned ledgers; explanation-anchoring designs are vulnerable to issuers that fabricate content before commitment [19]. Our receipt records a commitment to a calibration set and a bound rather than to an explanation, and we compare a signed Merkle log with a permissioned chain under named tampering cases rather than assuming either.

III. PROBLEM SETTING AND LEGAL SCOPE

A. Packages, Requests and Element States

A disclosure package X consists of elements $x_1, \dots, x_m$: structured FHIR R4 resources (conditions, observations, medication requests, procedures, encounters, attachments, claims) and narrative spans (sentences of the attached clinical note). A request q states the purpose, the item, the recipient, the recipient's published documentation requirement, and whether a purpose-matching Part 2 consent is on file. A versioned policy maps the documentation requirement to element states. We use five states rather than a closed allow-list because the CMS checklist describes its element list as "not all-inclusive" [3]: *required*, *conditional*, *potentially relevant*, *not justified*, and *prohibited without consent* (Part 2 content when no consent is on file), plus *unable to determine* for elements no rule covers. Excess is the union of *not justified* and *prohibited without consent*; the last is also the high-risk class.

Two decisions are kept separate. *Request conformance* asks whether an element is supported by the stated purpose, request and policy version; this is what the screener evaluates and what the labels encode. *Minimum necessary* in the legal sense additionally involves the sender's own obligations and is recorded as a human judgment only. The screener flags; it never removes or releases anything.

B. Legal Scope

The minimum-necessary standard does not apply to disclosures to or requests by a provider for treatment [1], so provider-to-provider referrals are out of scope and are not claimed. A covered entity may reasonably rely on a request from another covered entity as the minimum necessary [6], so for payer-bound prior-authorization packages only content beyond the payer's request is treated as checkable. Two flows remain where a necessity limit binds: substance-use disorder records under 42 CFR Part 2, whose uses and disclosures must be limited to the information necessary for the purpose [2], and prior-authorization packages containing elements beyond the payer's published documentation requirement, for which CMS-0057-F places machine-readable prior-authorization APIs on a January 2027 timeline [5]. Information blocking under 45 CFR 171 excludes practices required by law [20]; we therefore treat it as a workflow risk (review delay, unjustified flags) and report the corresponding rates rather than as a design driver.

C. Threat Model for the Audit Layer

Two adversaries are considered for the record store. A *post hoc editor* alters, deletes, reorders or backdates receipts after they are written. A *single colluding operator* rewrites the store's history and re-signs it with the operator's own key. The auditor is assumed to have captured a signed snapshot (a signed tree head or a block hash) at some earlier time. We do not model an issuer that lies before commitment; the certificate proves what was recorded and computed, not that the policy or the labels were correct.

IV. CERTIFIED SCREENING

A. Losses

A screener produces a score $s_j \in [0, 1]$ per element, larger meaning more likely excess, and flags element j when $s_j \geq \lambda$ for a threshold λ in a finite grid $\Lambda = \{\lambda_1 < \dots < \lambda_M\}$. The unit of exchangeability is the package: elements within a package are dependent, so all losses are defined per package and averaged over packages. With $E(X)$ the excess elements, $Q(X)$ the required elements and $H(X)$ the high-risk elements of package X ,

$$L_1(\lambda; X) = \frac{|\{j \in E(X) : s_j < \lambda\}|}{\max(1, |E(X)|)}, \quad (1)$$

$$L_2(\lambda; X) = \frac{|\{j \in Q(X) : s_j \geq \lambda\}|}{\max(1, |Q(X)|)}, \quad (2)$$

$$L_3(\lambda; X) = \mathbb{1}\{\exists j \in H(X) : s_j < \lambda\}. \quad (3)$$

L_1 (missed excess) and L_3 (a high-risk element released unflagged) are non-decreasing in λ ; L_2 (wrongful flags on required content, whose complement is required-element retention) is non-increasing. All are bounded in $[0, 1]$. Risks are $R_k(\lambda) = \mathbb{E}[L_k(\lambda; X)]$ under the test distribution, with targets α , β , α_3 and confidence $1 - \delta$. Given calibration packages $X_1, \dots, X_n$, $\hat{R}_k(\lambda) = \frac{1}{n} \sum_i L_k(\lambda; X_i)$.

B. Joint Certification

Theorem 1 (joint privacy–utility guarantee). *Assume the calibration packages and the test package are exchangeable. For each $\lambda \in \Lambda$ and $k \in \{1, 2, 3\}$ let $p_k(\lambda)$ be a valid p-value for the null $R_k(\lambda) > \alpha_k$ computed from $\hat{R}_k(\lambda)$ and n , and let $p(\lambda) = \max_k p_k(\lambda)$. Let $\hat{\Lambda}_\uparrow$ be the initial run of grid points, from the smallest λ upward, at which $\max(p_1, p_3) \leq \delta/2$, stopping at the first failure, and $\hat{\Lambda}_\downarrow$ the initial run from the largest λ downward at which $p_2 \leq \delta/2$; define $\hat{\Lambda} = \hat{\Lambda}_\uparrow \cap \hat{\Lambda}_\downarrow$. Then with probability at least $1 - \delta$ over the calibration draw, every $\lambda \in \hat{\Lambda}$ satisfies $R_1(\lambda) \leq \alpha$, $R_2(\lambda) \leq \beta$ and $R_3(\lambda) \leq \alpha_3$ simultaneously.*

Proof sketch. For fixed λ and k , the Hoeffding–Bentkus construction of Learn-then-Test yields a valid p-value for $R_k(\lambda) > \alpha_k$ from the bounded losses [14], [21], [22]. Under the union null “some $R_k(\lambda) > \alpha_k$ ” at least one component null holds, say k^* , and $\Pr(\max_k p_k \leq u) \leq \Pr(p_{k^*} \leq u) \leq u$, so $p(\lambda)$ is valid for the union null. Because L_1 and L_3 are non-decreasing in λ , a true null at some λ is true at every larger λ , so fixed-sequence testing upward that stops at the first non-rejection makes a false rejection only if the first true null is falsely rejected, with probability at most $\delta/2$; the same holds downward for the non-increasing L_2 . A union bound over the two families gives family-wise error at most δ ; this is the fixed-sequence variant of Learn-then-Test [14]. A Bonferroni variant ($\max_k p_k \leq \delta/M$ at every grid point) is valid without monotonicity but far more conservative. $\square$

If $\hat{\Lambda}$ is empty the procedure abstains and reports that no threshold on the grid can be certified at the targets with n packages. Otherwise any selection rule may choose $\hat{\lambda} \in \hat{\Lambda}$; we choose the certified threshold that minimizes flags per package on the calibration set. For the privacy risk alone, conformal risk control gives the marginal guarantee $\mathbb{E}[L_1(\hat{\lambda})] \leq \alpha$ with $\hat{\lambda} = \inf\{\lambda : \frac{n}{n+1} \hat{R}_1(\lambda) + \frac{1}{n+1} \leq \alpha\}$ [13]; the joint statement needs the high-probability form because L_2 moves in the opposite direction.

Corollary 1 (calibration size). *Under the Hoeffding p-value a threshold with empirical risks $\hat{R}_k(\lambda)$ is certifiable whenever $n \geq \log(2/\delta)/(2(\alpha_k - \hat{R}_k(\lambda))^2)$ for all k . Under the Hoeffding–Bentkus p-value with zero empirical risk, certification at target α_k requires $e(1 - \alpha_k)^n \leq \delta/2$; for $\delta = 0.05$ this is $n \geq 233$ at $\alpha_k = 0.02$ and $n \geq 469$ at $\alpha_k = 0.01$, which are the binding constraints on calibration size in this study.*

C. Transfer Across Organizations

Let calibration packages come from organization P and deployment packages from organization Q under covariate

shift: the package distribution differs but the loss given the package is the same. Let $w(X) = dQ_X/dP_X \leq W$ with $\mathbb{E}_P[w] = 1$, and $\hat{R}_k^w(\lambda) = \frac{1}{n} \sum_i w(X_i) L_k(\lambda; X_i)$.

Theorem 2 (transfer). *With probability at least $1 - \delta$, every λ in*

$$\hat{\Lambda}^w = \left\{ \lambda : \hat{R}_k^w(\lambda) + \epsilon_k(\lambda) \leq \alpha_k \quad \forall k \right\}$$

satisfies $R_k^Q(\lambda) \leq \alpha_k$ for all k , where $\epsilon_k(\lambda) = \sqrt{2\hat{V}_k(\lambda) \log(2/\delta')/n} + 7W \log(2/\delta')/(3(n-1))$ is the empirical Bernstein deviation [23] of the weighted losses, $\hat{V}_k$ their sample variance, and $\delta' = \delta/(3M)$. The Hoeffding form $\epsilon = W \sqrt{\log(3M/\delta)/(2n)}$ also holds.

Proof sketch. $\mathbb{E}_P[w(X) L_k(\lambda; X)] = \mathbb{E}_Q[L_k(\lambda; X)]$ by change of measure. The weighted losses lie in $[0, W]$, so the empirical Bernstein inequality (or Hoeffding) bounds the downward deviation of each weighted empirical risk; a union bound over M thresholds and three risks gives the claim. This specializes the importance-weighted results of [15], [16] to the finite-grid multi-risk case. $\square$

If the weights are estimated with uniform error at most η , the same conclusion holds after enlarging each margin by η , since $L_k \leq 1$. In the simulation the assembly pathway of each package is an observable covariate (as a FHIR Provenance resource would be), organizations are generated from known pathway mixtures, and weights are ratios of pathway frequencies; the experiment therefore tests the theorem sharply. A real deployment must estimate weights from package covariates and report the inflated bound.

D. Verifiable Screening Certificate

A screening certificate is

$$C = (h(D_{\text{cal}}), h(s), h(\pi, v), \Lambda, \hat{\lambda}, (\alpha, \beta, \alpha_3), \delta, n, \text{bound}, h(\ell))$$

where h is a collision-resistant hash, s the screener (rules, model weights and prompt), (π, v) the policy and version, and ℓ the table of per-package losses on the grid. A receipt for package X binds salted commitments to the package and request, the certificate hash, the flags, the confidence, the human decision, a signer identity and a timestamp, and is appended to a signed Merkle log [18] or, under a multi-operator distrust model, a permissioned chain.

Proposition 1 (verifiability). *Given C and either D_{cal} or ℓ , a verifier can decide deterministically whether $\hat{\lambda} \in \hat{\Lambda}$ (or $\hat{\Lambda}^w$). Any alteration of D_{cal} , s , π , the targets, n or $\hat{\lambda}$ after certification is detected by a hash mismatch or by failure of the recomputation; alteration, deletion or reordering of a logged receipt is detected by the log's inclusion and consistency proofs.*

The proposition is definitional: $\hat{\Lambda}$ is a deterministic function of $(\ell, \Lambda, \text{targets}, \delta, n)$ and ℓ of $(D_{\text{cal}}, s, \pi, \Lambda)$. The verifier needs no patient data, since ℓ contains only numbers in $[0, 1]$. The certificate proves that a stated guarantee was computed from committed inputs and not changed afterwards; it does not prove that the calibration set was representative, that the policy is legally correct, or that any human decision was right.

E. Screeners

Five screeners are compared, all producing element scores in $[0, 1]$: (i) a deterministic request allow-list derived from the policy, using resource type, code sets, encounter linkage and reason linkage, and section headers and keyword matching for narrative spans; (ii) HL7 DS4P sensitivity labels plus the consent rule, which score only Part 2 content; (iii) an identifier baseline, Presidio with the spaCy `en_core_web_lg` model [9], scoring narrative spans by the number of identifier entities found and structured elements zero, reported because it is what a data-loss-prevention tool does; (iv) a local language model (Qwen 3.5, 4B parameters, temperature 0, structured JSON output) given the request, the qualifying diagnoses, the consent flag and batches of element descriptions, returning a probability of excess per element; and (v) a policy-bounded hybrid that keeps the rule score wherever the rules are decisive and sends only rule-uncertain elements to the model. Screeners (i), (ii) and (iii) run on every package; (iv) and (v) run on a stratified subset because of local inference cost, and all five are additionally compared on that common subset.

V. BENCHMARK AND WORKFLOW SIMULATION

A. Synthetic Population

Patients are generated with Synthea [24] (FHIR R4 export with US Core profiles, ten years of history, per-encounter clinical notes as DocumentReference resources). Two populations are generated with fixed seeds: a general population and a population aged 40 to 95. A patient is eligible when at least one active diagnosis falls in a mobility code set derived from the generated inventory by fixed keyword rules (osteoarthritis of knee and hip, osteoporosis, diabetic neuropathy, hip fracture, chronic obstructive bronchitis, emphysema, gout, heart failure, cerebral palsy, rheumatoid arthritis, spinal-cord conditions and lower-limb amputation), the patient is at least 40 years old at the most recent ambulatory encounter with a note, and that encounter exists. Substance-use disorder content is identified by a second code set (unhealthy alcohol use, overdose, dependent drug abuse, opioid abuse, alcoholism; buprenorphine–naloxone and naltrexone prescriptions). The code sets are released with the benchmark.

B. Package Assembly and Labels

For each eligible patient the most recent ambulatory encounter with a note is designated the face-to-face mobility examination. Every candidate element of the patient's record is labelled once from the policy and the request, before any mechanism decides what to include: mobility diagnoses and medications linked to them are required; weight and height at the examination are required; an order and a product description are added as required elements; other active conditions, examination vitals at the encounter, allergies and care plans linked to the mobility diagnoses are potentially relevant; resources from other encounters, immunizations, claims, financial records, imaging and unrelated procedures are not justified; Part 2 content is prohibited without consent and potentially relevant with consent (consent is on file for 30 percent of packages). The face-to-face note is the patient's actual

Synthea note for that encounter with a templated mobility-examination section appended (covering items C.1.a to C.2.d of the checklist), whose sentences are required; sentences copied from other encounters are not justified; sentences mentioning substance use are prohibited without consent; the remaining sentences of the base note are unable to determine and count in neither loss.

C. Over-Disclosure Mechanisms and Organizations

A package starts from the request-conformant core and one of six mechanisms adds content: M1 whole-chart export, M2 whole-encounter bundles from one to three other encounters, M3 copy-forward text from other notes inserted into the face-to-face note, M4 a wrong template adding respiratory-template content, M5 Part 2 records and a Part 2 sentence without consent, and M6 attachment metadata pointing to unrelated notes. Packages with no mechanism are clean. Four generated organizations draw the mechanism with different probabilities; three form the calibration pool and the fourth, with a heavier whole-chart and copy-forward habit, is held out entirely, by patient and by organization. The assembly pathway is stored with each package as an observable covariate. An adversarial variant of every calibration-pool package inserts a prompt-injection sentence into the note.

D. Workflow Simulation

A simulated reviewer accepts a correct flag with probability 0.70, 0.85 or 0.95 and accepts a wrong flag on a non-excess element with probability 0.30, 0.15 or 0.05, at 0.5, 1 or 2 minutes per flag. Outcomes per 1,000 packages are residual excess elements released, review minutes, false flags and required elements removed by the reviewer. The screener itself never removes anything, so required-element removal is a reviewer outcome, not a screener outcome.

E. Audit Stores and Tampering Cases

Receipts are written to three stores: a plain database, a signed Merkle log with signed tree heads (RFC 9162 style), and a permissioned proof-of-authority chain with three validators and 2-of-3 block signatures. Tampering cases are: edit a decision, delete a receipt, reorder, backdate, a single operator rewriting and re-signing history, and two of three validators colluding. The auditor verifies against a snapshot captured before the tampering. Certificate recomputation is tested by altering one entry of the committed loss table and by swapping the certified threshold.

VI. EXPERIMENTAL PROTOCOL

The protocol was written before any package was generated and is released with the code. Targets are $\alpha = 0.05$ (missed excess), $\beta = 0.02$ (wrongful flags on required elements), $\alpha_3 = 0.01$ (a high-risk element released unflagged), $\delta = 0.05$, and a grid of $M = 100$ thresholds on $(0, 1]$. Pre-registered hypotheses: (H1) on structured elements the rule set reaches excess recall at or above the language model at matched required-element retention; (H2) on narrative elements the

policy-bounded hybrid has higher excess recall than rules alone and than the model alone at matched retention; (H3) the screener reduces residual excess per 1,000 packages while adding review minutes, reported as a curve with no pre-specified direction; (H4) prompt injection degrades the model alone more than the hybrid, and policy drift degrades rules more than the hybrid; (H5) under a single-operator threat model the signed Merkle log detects every tested tampering case at lower cost than the chain, and under collusion the chain detects what the single-operator log does not. Certification hypotheses: (H-T1) across 20 calibration/test splits the certified threshold's test risks satisfy the targets in at least 95 percent of splits; (H-T2) on the held-out organization the unweighted procedure violates a target while the weighted procedure does not; (H-T3) every tampering case is detected by certificate recomputation or by the log proof, reported as a check; (H-T4) the identifier baseline yields an empty certified set at the targets while the hybrid does not.

Splits are by patient and organization: each patient contributes one package, and the held-out organization contributes no package to calibration. Twenty random calibration/test halves of the calibration pool are drawn with fixed seeds. The threshold is chosen on the calibration half and applied unchanged to the test half. Rule files and prompts were fixed before the test packages were scored. Every number reported is regenerated from the released outputs by a single script; tables in this paper are produced by that script rather than transcribed.

Deviations from the pre-registered protocol are recorded in the amendment log released with the code. In this run the population was extended with a second Synthea cohort to reach the calibration size implied by the corollary, and the language-model screeners were evaluated on a stratified subset because of local inference cost; both changes were made before any test package was scored.

VII. RESULTS

A. Benchmark

The two Synthea cohorts yielded 1360 packages from 1360 eligible patients (one package per patient): 1020 in the three calibration organizations and 340 in the held-out organization. Packages contain 134.1 elements on average, 182357 in total (123386 structured, 58971 narrative), of which 47667 are required, 79035 not justified, 1000 prohibited without consent, 25762 potentially relevant, 1306 conditional and 27587 unable to determine. The held-out organization draws whole-chart export in 126 of its 340 packages and copy-forward text in 109, against 38 and 65 of 340 in organization A; the resulting importance weights are bounded by $W = 3.23$.

B. Certification (Theorem 1)

Table I and Fig. 1 report the certification outcome over 20 calibration/test splits of the 1020 calibration-pool packages. The request allow-list obtained a non-empty certified set in every split, with the same certified interval $[0.01, 0.40]$ in each, and its selected threshold produced test risks of $\hat{R}_1 = 0.004$, $\hat{R}_2 = 0.000$ and $\hat{R}_3 = 0.000$ against targets

TABLE I

CERTIFICATION OUTCOMES ACROSS 20 CALIBRATION/TEST SPLITS (TARGETS $\alpha = 0.05$, $\beta = 0.02$, $\alpha_3 = 0.01$, $\delta = 0.05$, GRID $M = 100$). EMPIRICAL TEST RISKS ARE MEANS OVER SEEDS WITH A CERTIFIED THRESHOLD; VIOLATION RATE IS THE FRACTION OF CERTIFIED SEEDS WHOSE TEST RISK EXCEEDED A TARGET.

Screener	n pkgs	Certified seeds (%)	$\hat{\lambda}$ median	$\hat{R}_1$ miss	$\hat{R}_2$ wrong	$\hat{R}_3$ Request high-risk	Viol. allow-list (rules)
Request allow-list (rules)	1020	100.0	0.31	0.004	0.000	0.000	0.0
DS4P sensitivity labels	1020	0.0	—	—	—	—	—
Identifier redactor (Presidio)	1020	0.0	—	—	—	—	—

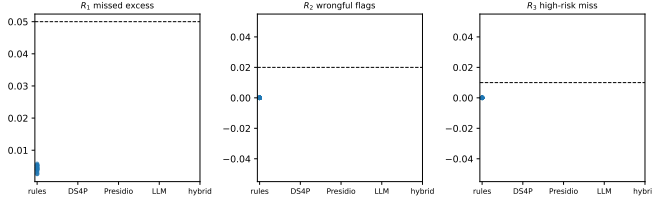


Fig. 1. Empirical test risks at the certified threshold across 20 splits (dots) against the targets (dashed). Screeners without a dot abstained in every split.

of 0.05, 0.02 and 0.01; no split violated any target (H-T1). The marginal conformal-risk-control threshold for the privacy risk alone coincided with the upper end of the certified interval ($\lambda = 0.40$) and gave test $\hat{R}_1$ between 0.003 and 0.005. The DS4P sensitivity labels and the identifier redactor abstained in every split: neither screener can bring the missed-excess risk below α at any threshold, because the first flags only Part 2 content and the second flags identifiers regardless of necessity (H-T4). On the common 360-package subset the allow-list also abstained, for a different reason: a calibration half of 180 packages is below the $n \geq 469$ floor implied by the corollary for $\alpha_3 = 0.01$, so no threshold can be certified there whatever the screener; this is the sample-size cost of the joint guarantee and it applies equally to the language-model screeners evaluated on subsets (Section VII-H).

C. Element-Level Performance

At the certified threshold the allow-list reached excess recall of 1.00 on structured elements and 0.98 on narrative spans with required-element retention of 1.000 on both (Table II), and missed no high-risk package among the 161 test packages containing Part 2 content. Precision was 0.73 on structured elements and 0.25 on narrative spans, and the screener raised 90 flags per package on average. The narrative precision reflects the design of the rule set: sentences the rules cannot place (base-note text labelled unable to determine, which counts in neither risk) receive scores of 0.4 to 0.5 and are flagged at $\lambda = 0.31$. This is the review burden that a narrative-capable screener must reduce without giving up the certified risks.

D. Transfer to the Held-Out Organization (Theorem 2)

Table III reports the transfer experiment. The unweighted allow-list threshold certified on the calibration organizations

TABLE II

ELEMENT-LEVEL PERFORMANCE AT THE CERTIFIED THRESHOLD, AVERAGED OVER CERTIFIED SEEDS (TEST SPLIT). RETENTION IS THE FRACTION OF REQUIRED ELEMENTS NOT FLAGGED.

Screener	Structured			Narrative			Flags /pkg
	P	R	Ret.	P	R	Ret.	
	0.73	1.00	1.000	0.25	0.98	1.000	90.1

TABLE III

TRANSFER TO THE HELD-OUT ORGANIZATION. UNWEIGHTED CERTIFICATION USES THE CALIBRATION ORGANIZATIONS ONLY; WEIGHTED CERTIFICATION APPLIES THEOREM 2 WITH IMPORTANCE WEIGHTS BOUNDED BY W . TARGET RISKS ARE MEASURED ON THE HELD-OUT ORGANIZATION.

Screener	W	Unweighted $\hat{\lambda}$	Unweighted R_1^Q	Weighted $\hat{\lambda}$	Weighted R_1^Q	Viol. (U/W)
Request allow-list (rules)	3.23	0.40	0.009	—	—	no/abstain
DS4P sensitivity labels	3.23	—	—	—	—	abstain/abstain
Identifier redactor (Presidio)	3.23	—	—	—	—	abstain/abstain

held on the held-out organization ($R_1^Q = 0.009$, $R_2^Q = R_3^Q = 0$, no violation), even though the held-out organization exports whole charts three times as often. The weighted procedure of Theorem 2 abstained: with $W = 3.23$ the second term of the empirical Bernstein margin alone, $7W \log(2/\delta')/(3(n-1)) = 0.069$ at $n = 1020$, exceeds $\beta = 0.02$, so no threshold can be certified for the required-element risk at this calibration size. Certifying the transfer at these targets would need roughly 3,500 calibration packages, or a milder shift. The pre-registered hypothesis H-T2 is therefore not supported in either direction: the unweighted threshold did not violate, and the weighted threshold could not be certified. We report this as the practical cost of the transfer bound rather than as evidence that the bound is wrong.

E. Drift and Attack

At the seed-0 certified threshold the allow-list was unaffected by prompt injection ($R_1 = 0.001$ on the 60 injected packages; the injected sentence is itself flagged as not justified) and by the policy-version change ($R_1 = 0.005$, $R_2 = 0$), because the rules never score examination vitals or weight and height above the threshold (Table IV). Padded-purpose and resource-reordering conditions apply only to the language-model screeners (Section VII-H).

F. Workflow Outcomes

Without screening, the test packages release 52,355 excess elements per 1,000 packages. With the allow-list and a simulated reviewer, residual excess falls to 15,963, 8,157 and 2,818 per 1,000 packages at reviewer agreement of 0.70, 0.85 and 0.95, a reduction of 70 to 95 percent, at a cost of 89,967 review minutes per 1,000 packages at one minute per flag, of which 37,788 minutes are spent on false flags (Table V, Fig. 2). Because the screener only flags, no required element is removed by the screener; reviewer removal of required elements is reported in the released outputs and was zero at

TABLE IV
ROBUSTNESS AT THE SEED-0 CERTIFIED THRESHOLD: RISKS UNDER
DRIFT AND ATTACK CONDITIONS (R_1 MISSED EXCESS, R_2 WRONGFUL
FLAGS ON REQUIRED ELEMENTS).

Screener	Condition	n	R_1	R_2	Narr
Request allow-list (rules)	clean	510	0.005	0.000	
Request allow-list (rules)	prompt injection	60	0.001	0.000	
Request allow-list (rules)	policy drift v2	510	0.005	0.000	

TABLE V
WORKFLOW OUTCOMES PER 1,000 PACKAGES (TEST SPLIT, SEED 0) WITH
A SIMULATED REVIEWER AT THREE AGREEMENT LEVELS AND ONE
MINUTE PER FLAG. NO-SCREENER BASELINE SHOWN FOR REFERENCE.

Screener	Reviewer	Residual excess	Review mi
Request allow-list (rules)	low	15963	89967
Request allow-list (rules)	medium	8157	89967
Request allow-list (rules)	high	2818	89967
Request allow-list (rules) (none)	none	52355	52355

every agreement level, because the allow-list never flagged a required element.

G. Audit Layer (Proposition 1)

Certificate recomputation from the committed loss table reproduced the certified set and confirmed the selected threshold; altering one loss-table entry and substituting a threshold outside the certified interval were both detected. Table VI reports the tampering suite over 200 receipts. The plain database detected nothing. The signed Merkle log detected every case, including the single operator rewriting and re-signing history, because the auditor’s previously captured signed tree head cannot be reproduced from the rewritten leaves. The proof-of-authority chain also detected every case, including collusion of two of three validators, for the same reason: the auditor’s captured block hash no longer matches. Per receipt, the chain’s append cost was lower (0.02 ms, amortized over eight-receipt blocks) and its verification cost higher (8.7 ms against 1.2 ms for a clean log). Under the tested threat model the chain detected nothing that the signed log with a captured snapshot did not; the second clause of H5 is therefore not supported, and, as pre-registered, the chain is not claimed as a contribution.

H. Language-Model Screeners

[PENDING: local-model scoring of the policy-bounded hybrid and the model-alone screener was running at the time of this draft (Qwen 3.5 4B, CPU inference, roughly one minute per batch of 28 elements). In a two-package timing test the model alone flagged 4 of 20 and 15 of 19 required elements as excess, where the rules flagged none, which is the pattern H1 predicts. Rows for both screeners, the same-subset comparison, the padded-purpose and reordering conditions, and the injection results for the model-based screeners will be inserted from the released outputs by the table script; no number will be typed by hand.]

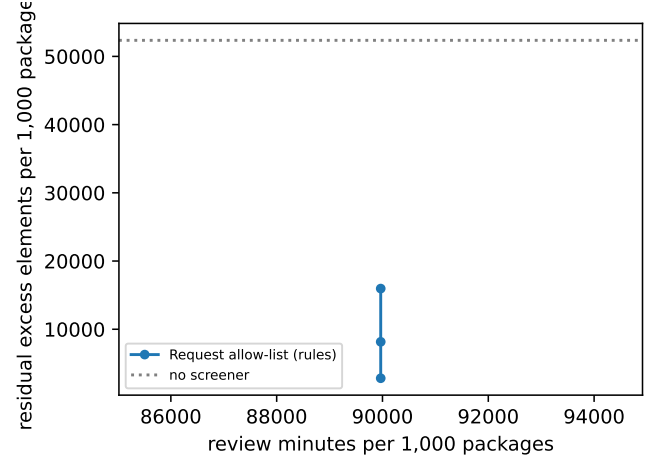


Fig. 2. Residual excess against review minutes per 1,000 packages at one minute per flag across reviewer agreement levels.

TABLE VI
TAMPERING DETECTION BY RECORD STORE (200 RECEIPTS).
VERIFICATION TIME IS THE AUDITOR-SIDE CHECK AGAINST A
PREVIOUSLY CAPTURED SNAPSHOT.

Store	Case	Detected	Append (ms)	Verify (ms)
plain db	none	no	0.001	0.03
plain db	edit decision	no	0.001	0.00
plain db	delete receipt	no	0.001	0.00
plain db	reorder	no	0.001	0.00
plain db	backdate	no	0.001	0.00
plain db	operator rewrite	no	0.001	0.00
plain db	one validator collusion	n/a	0.001	–
merkle log	none	no	1.305	4.48
merkle log	edit decision	yes	1.117	2.13
merkle log	delete receipt	yes	1.063	0.54
merkle log	reorder	yes	1.117	1.82
merkle log	backdate	yes	1.260	2.68
merkle log	operator rewrite	yes	1.552	1.40
merkle log	one validator collusion	n/a	2.041	–
poa chain	none	no	0.216	85.75
poa chain	edit decision	yes	0.244	0.19
poa chain	delete receipt	yes	0.151	0.36
poa chain	reorder	yes	0.223	0.03
poa chain	backdate	yes	0.214	0.46
poa chain	operator rewrite	yes	0.164	10.15
poa chain	one validator collusion	yes	0.195	117.58

VIII. DISCUSSION

What the certification buys. The allow-list’s certified interval was identical in all 20 splits and its test risks sat an order of magnitude below the targets. A reader might conclude that certification was unnecessary for so clean a screener. The opposite reading is the useful one: the same procedure abstained for two screeners that a practitioner might otherwise deploy, the identifier redactor and the sensitivity labels, and it abstained for the allow-list itself when the calibration set was too small. The procedure does not only bless good screeners; it refuses to bless screeners that cannot meet the targets and calibration sets that cannot support the claim. That refusal is the safety property.

Sample size is the binding constraint. With the Hoeffding–Bentkus p-value, certifying $\alpha_3 = 0.01$ needs at least 469 calibration packages even with zero observed misses, and

certifying a transfer at $W = 3.23$ needs several thousand. These numbers follow from the corollary and from the second term of the Bernstein margin, not from the screeners. In deployment they translate into a concrete requirement: an organization must label on the order of five hundred packages before it can claim the joint guarantee at these targets, and more if it wants to inherit a guarantee calibrated elsewhere. Organizations that cannot label that many packages can still certify the privacy risk alone with the marginal conformal bound, which needs no δ and worked at every split here, or can certify at looser targets.

Structured versus narrative. On structured FHIR elements a deterministic allow-list built from the payer’s own checklist reached recall 1.00 with zero wrongful flags. Whatever a language model adds must therefore come from narrative text and from the elements the rules cannot place, and it must do so without raising the required-element risk above β ; the two-package timing test, in which the model alone wrongly flagged most required elements, shows why the hybrid design keeps the rules in charge of everything they can decide. H1 is supported on the structured side; H2 awaits the pending model results.

Review burden. Ninety flags per package is not a deployable operating point. It is, however, the honest consequence of a rule set that scores base-note sentences at 0.4 to 0.5 and a certified threshold of 0.31: the guarantee forces the threshold low enough to catch excess, and the rules cannot separate ordinary note text from copied text. The workflow simulation makes the cost visible in minutes rather than hiding it in a precision figure, and it identifies the quantity a better narrative screener must move.

The audit layer. The pre-registered test of the permissioned chain failed in the direction the protocol anticipated: with an auditor who holds a signed snapshot, a signed Merkle log detected every tampering case the chain did, at lower verification cost. The certificate, not the ledger, is what makes the receipt scientifically meaningful, because it lets an auditor recompute a statistical guarantee from committed numbers without patient data. We have accordingly kept the word blockchain out of the title and the contribution list.

Transfer. That the unweighted threshold held on an organization that exports whole charts three times as often is encouraging but not a guarantee, and the weighted procedure’s abstention is the guarantee being honest about n and W . The experiment does show what the theorem promises to deliver once the calibration set is large enough, and it gives the sample-size formula an organization would use to plan.

IX. LIMITATIONS

The guarantees are distribution-free with respect to the package distribution but conditional on the policy-derived labels being the ground truth. The labels encode request conformance under one policy version for one item; an independent expert validation of a labelled sample, planned in the protocol, was not completed for this draft, and the manuscript therefore makes no external-validity claim about the labels themselves. Theorem 2 requires the covariate-shift assumption and bounded, known or well-estimated weights; in the

simulation the weights are exact by construction because the assembly pathway is observable, while a real deployment must estimate them from package covariates and report the inflated bound. Label shift between organizations is not covered. The synthetic population follows Synthea’s disease modules, so the mobility and substance-use code sets reflect what that generator produces rather than a Medicare population; the mobility-examination narrative is templated and is easier to recognize than clinician prose; and the copy-forward and whole-chart mechanisms are stylized versions of real export behavior. The language-model screeners were evaluated on a stratified subset because of local inference cost, so their certification estimates rest on fewer packages than the rule-based screeners. The reviewer model is a two-parameter simulation, not observed behavior. The audit comparison covers named tampering cases against a captured snapshot; it does not model an issuer that lies before commitment, nor key compromise. No result establishes performance on real organizational traffic, and none makes a disclosure lawful, replaces the human decision, or constitutes legal advice.

X. CONCLUSION

We formulated outbound health-data disclosure screening as joint risk control over missed excess, wrongful flags on required content and high-risk misses, gave a finite-sample distribution-free certification procedure and a transfer bound, and bound the resulting certificate into an audit receipt that an auditor can recompute without patient data. On a released benchmark of 1360 synthetic FHIR packages with policy-derived labels and six over-disclosure mechanisms, a request allow-list derived from the CMS checklist was certified in every split with test risks far below the targets, while an identifier redactor and sensitivity labels were correctly refused. The transfer bound abstained at the available calibration size, the chain added nothing over a signed log with a captured snapshot, and the certified allow-list carries a review burden that a narrative-capable screener must reduce. The guarantees are conditional on the policy-derived labels and are demonstrated on synthetic data; a deployment inherits them by calibrating on its own packages, and the calibration-size formulas in this paper say how many.

REFERENCES

- [1] U.S. Code of Federal Regulations, “45 CFR 164.502, uses and disclosures of protected health information: general rules,” <https://www.law.cornell.edu/cfr/text/45/164.502>, 2026.
- [2] —, “42 CFR 2.13, confidentiality restrictions and safeguards,” <https://www.law.cornell.edu/cfr/text/42/2.13>, 2026.
- [3] Centers for Medicare & Medicaid Services, “Documentation checklist for prior authorization request: Certain power mobility devices (K0856 and K0861),” https://www.cms.gov/Research-Statistics-Data-and-Systems/Monitoring-Programs/Medicare-FFS-Compliance-Programs/DMEPOS/Downloads/DMEPOS_PA_Documentation_Checklist_2017-03-24.pdf, 2017.
- [4] HL7 International, “HL7 da vinci documentation templates and rules (DTR) implementation guide,” <https://hl7.org/fhir/us/davinci-dtr/>, 2025.
- [5] Centers for Medicare & Medicaid Services, “CMS interoperability and prior authorization final rule (CMS-0057-F),” <https://www.cms.gov/initiatives/burden-reduction/overview/interoperability/policies-regulations/cms-interoperability-prior-authorization-final-rule-cms-0057-f>, 2024.

- [6] U.S. Code of Federal Regulations, “45 CFR 164.514, other requirements relating to uses and disclosures of protected health information,” <https://www.law.cornell.edu/cfr/text/45/164.514>, 2026.
- [7] arXiv:2312.10214 authors, “Healthcare policy compliance: A blockchain smart contract-based approach,” *arXiv preprint arXiv:2312.10214*, 2023.
- [8] arXiv:2604.09630 authors, “Adoption and effectiveness of AI-based anomaly detection for cross provider health data exchange,” *arXiv preprint arXiv:2604.09630*, 2026.
- [9] Microsoft, “Presidio: Data protection and de-identification SDK,” <https://github.com/microsoft/presidio>, 2025.
- [10] HL7 International, “HL7 FHIR data segmentation for privacy (DS4P) implementation guide,” <https://build.fhir.org/ig/HL7/fhir-security-label-ds4p/>, 2025.
- [11] W. Fan, H. Li, Z. Deng, W. Wang, and Y. Song, “GoldCoin: Grounding large language models in privacy laws via contextual integrity theory,” *arXiv preprint arXiv:2406.11149*, 2024.
- [12] X. Huang, X. Cao, and W. Yang, “Need to know: Contextual-integrity-grounded query rewriting for privacy-conscious LLM delegation,” *arXiv preprint arXiv:2606.04067*, 2026.
- [13] A. N. Angelopoulos, S. Bates, A. Fisch, L. Lei, and T. Schuster, “Conformal risk control,” *arXiv preprint arXiv:2208.02814*, 2022, revised June 2025.
- [14] A. N. Angelopoulos, S. Bates, E. J. Candès, M. I. Jordan, and L. Lei, “Learn then test: Calibrating predictive algorithms to achieve risk control,” *arXiv preprint arXiv:2110.01052*, 2021.
- [15] M. Zecchin, F. Hellström, S. Park, S. Shamaï, and O. Simeone, “Generalization and informativeness of weighted conformal risk control under covariate shift,” *arXiv preprint arXiv:2501.11413*, 2025.
- [16] T. Aldirawi, Y. Li, and W. Guo, “Conformal risk control under non-monotone losses: Theory and finite-sample guarantees,” *arXiv preprint arXiv:2604.01502*, 2026.
- [17] V. Kotte, “When can conformal risk control certify LLM outputs? bounds, impossibility, and adaptation for structured generation,” *arXiv preprint arXiv:2606.29054*, 2026.
- [18] B. Laurie, E. Messeri, and R. Stradling, “Certificate transparency version 2.0,” Internet Engineering Task Force, Tech. Rep. RFC 9162, 2021.
- [19] D. Slack, S. Hilgard, E. Jia, S. Singh, and H. Lakkaraju, “Fooling LIME and SHAP: Adversarial attacks on post hoc explanation methods,” *Proceedings of the AAAI/ACM Conference on AI, Ethics, and Society*, 2020.
- [20] U.S. Code of Federal Regulations, “45 CFR 171.103, information blocking,” <https://www.law.cornell.edu/cfr/text/45/171.103>, 2026.
- [21] W. Hoeffding, “Probability inequalities for sums of bounded random variables,” *Journal of the American Statistical Association*, vol. 58, no. 301, pp. 13–30, 1963.
- [22] V. Bentkus, “On Hoeffding’s inequalities,” *The Annals of Probability*, vol. 32, no. 2, pp. 1650–1673, 2004.
- [23] A. Maurer and M. Pontil, “Empirical Bernstein bounds and sample variance penalization,” *Proceedings of the 22nd Conference on Learning Theory (COLT)*, 2009.
- [24] J. Walonoski, M. Kramer, J. Nichols, A. Quina, C. Moesel, D. Hall, C. Duffett, K. Dube, T. Gallagher, and S. McLachlan, “Synthea: An approach, method, and software mechanism for generating synthetic patients and the synthetic electronic health care record,” *Journal of the American Medical Informatics Association*, vol. 25, no. 3, pp. 230–238, 2018.